

PNK Suguan 1.0.1 — User / Role Guide

PNK Suguan 1.0.1 — release documentation (source: USER-ROLE-GUIDE.md)

PNK Suguan uses **four roles**. Every permission below is enforced **server-side** on each API route: hiding a button in the interface is never the security boundary, and a request sent by hand is checked exactly like a request sent by the page.

Role code	Name you see in the interface	Who it is for
ADMIN	Administrator	Full day-to-day administration of the system
SCHEDULER	Scheduler / Encoder	Encoding and revising schedules
VIEWER	Viewer	Read-only access to schedules and reports
SUPER_ADMIN	Super Admin	Emergency published-week correction only

ADMIN, SCHEDULER and VIEWER can be assigned from the **Users** page. **`SUPER\_ADMIN` cannot** — it is provisioned deliberately by an operator outside the application, so it can never be granted by mistake through the user interface.

1. Permission matrix

Yes = permitted. No = denied.

Permission	Administrator (ADMIN)	Scheduler/Encoder (SCHEDULER)	Viewer (VIEWER)	Super Admin (SUPER_ADMIN)
users.manage — create/edit users, roles, resets	Yes	No	No	Yes
teachers.read	Yes	Yes	Yes	Yes
teachers.write	Yes	Yes	No	Yes
dako.read	Yes	Yes	Yes	Yes
dako.write	Yes	Yes	No	Yes
weeks.read	Yes	Yes	Yes	Yes
weeks.write	Yes	Yes	No	Yes
weeks.finalize	Yes	No	No	Yes
weeks.publish	Yes	No	No	Yes
weeks.unlock — FINALIZED revision window	Yes	Yes	No	Yes
availability.read	Yes	Yes	Yes	Yes
availability.write	Yes	Yes	No	Yes
assignments.read	Yes	Yes	Yes	Yes
assignments.write	Yes	Yes	No	Yes
assignments.override	Yes	No	No	Yes
assignments.history.read	Yes	Yes	Yes	Yes
assignments.counts.read	Yes	Yes	Yes	Yes

scheduling.generate — generate a DRAFT schedule	Yes	Yes	No	Yes
notifications.read	Yes	Yes	Yes	Yes
notifications.write	Yes	No	No	Yes
audit.read	Yes	No	No	Yes
reports.read	Yes	Yes	Yes	Yes

Super Admin holds exactly the Administrator permission set (marked Yes in both columns above). What makes it different is **not** in this table: the published-week correction capability, described in section 4.

2. Administrator (`ADMIN`)

The everyday full-function role.

Can: manage users and roles; maintain teachers and dako records; generate DRAFT schedules; encode weekly assignments; finalize a week; publish a finalized week; open the FINALIZED revision window; override certain hard scheduling rules *with a reason*; read and write availability; read assignment history and counts; read the audit log; write notifications; read reports.

Cannot: correct a PUBLISHED week (that is Super Admin only).

Two rules remain outside its reach entirely: LANGUAGE_MISMATCH and DAKO_DISABLED cannot be overridden by **any** role, Administrator included, and a reason cannot unlock them.

3. Scheduler / Encoder (`SCHEDULER`)

The schedule-encoding role. It is a **working** role, not a read-only one: it writes master data, availability and assignments, and it may revise a finalized week.

Can: read and write teachers and dako; generate DRAFT schedules; encode and change weekly assignments; read and write availability; open the FINALIZED revision window (with a reason); read assignment history and counts; read reports and notifications.

Explicitly cannot — the following are **not** available to this role in the validated release:

Not permitted for Scheduler/Encoder	Why it matters
weeks.finalize	It cannot finalize a week
weeks.publish	It cannot publish a week
assignments.override	It cannot override a hard scheduling rule
users.manage	It cannot create or modify user accounts
audit.read	It cannot read the audit log
notifications.write	It cannot author notifications

A caution about the FINALIZED revision window. Scheduler/Encoder *does* hold weeks.unlock, which authorizes the **FINALIZED** revision window only. It does **not** confer the ability to finalize or publish, and it does **not** allow any correction to a PUBLISHED week. Do not describe this role as being able to finalize, publish, or correct published weeks: it cannot.

4. Super Admin (`SUPER\_ADMIN`)

An **exceptional emergency role** for one situation: a week has been published and must be corrected anyway.

- It is **not** created at first run.
- It **cannot** be granted from the Users page.
- Its permission set is identical to Administrator; the published-correction capability is a separate,

additional check.

To correct a PUBLISHED week, the holder must present the account's normal authentication **plus** the unlock secret held in `%LOCALAPPDATA%\PNK_Suguan\.env` as `PNK_SUPER_ADMIN_SECRET`. The capability is:

- **time-boxed** — the correction window is temporary and closes on its own (default 30 minutes);
- **reason-required** — a correction cannot be recorded without a stated reason;
- **week-scoped and holder-scoped** — it applies to one published week and to the account that opened it;
- **status-preserving** — the week keeps its PUBLISHED status; it does not revert to DRAFT and nothing is

globally unlocked;

- **audited** — opening, using and closing are recorded;
- **fail-closed** — with the secret absent, the endpoint refuses every request rather than opening up;
- **refused to every other role** — Administrator, Scheduler/Encoder and Viewer all receive an

authorization denial, not a partial success.

There is no hidden administrator account and no backdoor: the application creates exactly one administrator, at first run, and that account is a normal **Administrator**.

5. Viewer (`VIEWER`)

Read-only. Intended for people who need to see schedules, availability and reports without changing anything (for example, a coordinator reviewing a published week).

Can: read teachers, dako, weeks, availability, assignments, assignment history and assignment counts; read notifications; read reports.

Cannot: change anything. Specifically, Viewer holds **no** write or administrative permission — no teacher/dako edits, no availability edits, no assignment writes, no schedule generation, no finalize, no publish, no FINALIZED revision window, no overrides, no user management, and **no** access to the audit log. Viewer can read notifications but cannot create them.

One consequence is worth calling out because it is easy to assume otherwise: producing the printable **Weekly Suguan PDF** requires `assignments.write`, so a **Viewer cannot generate it** (the request is denied with 403). A Viewer sees the schedule and the reports on screen, but not the printed form.

A Viewer's requests are rejected by the server **even if** a write request is constructed manually.

6. What the roles mean for the week lifecycle

Action	Who may do it
Create / maintain a DRAFT week schedule (<code>scheduling.generate</code>)	Administrator, Scheduler/Encoder
Encode or change assignments in a DRAFT or FINALIZED week	Administrator, Scheduler/Encoder
Revise a FINALIZED week (correction window, reason required)	Administrator, Scheduler/Encoder, Super Admin
Finalize a week	Administrator, Super Admin

Publish a finalized week	Administrator, Super Admin
Correct a PUBLISHED week	Super Admin only
Produce the printable Weekly Suguan PDF (requires assignments.write)	Administrator, Scheduler/Encoder
Read schedules, availability, assignments, reports	All four roles

Schedule generation is **DRAFT-only**: no role can generate a schedule directly into a finalized or published week.

7. Assigning roles safely

- Give the smallest role that gets the work done. Reviewers are usually Viewer; encoders are usually Scheduler/Encoder; only the person accountable for publishing a week needs Administrator.

- A user may hold more than one role; permissions are the **union** of their roles.
- When someone leaves or changes duties, deactivate the account rather than leaving it unused. A

deactivated user's sessions stop being accepted immediately.

- Do not create shared accounts. Per-user accounts are what make the audit log, assignment history and the correction record meaningful.